

Pramo Jewels

Authentication & Authorization Design

Document ID: PJ-AUTH-001
Version: 1.0
Status: Approved for Development

Field	Value
Project	Pramo Jewels Premium E-Commerce Platform
Purpose	Define identity management, authentication flows and authorization architecture
Audience	Backend Developers, Frontend Developers, Security Architects, QA, DevOps
Version	1.0

RBAC Permission Matrix

Role	Core Permissions
Customer	Browse, purchase, manage profile, orders, wishlist, reviews
Support	View customers/orders, assist returns, limited updates
Inventory Manager	Manage products, inventory and catalog
Admin	Manage users, orders, products, coupons, reports
Super Admin	Full platform administration, roles, settings and security

Authentication Flow

Register → Email/Mobile OTP Verification → Login → Issue Laravel Sanctum Token → Access Protected APIs → Logout / Token Revocation.

Authorization Model

Use Role-Based Access Control (RBAC) with policy classes and middleware. Apply least-privilege access to every protected resource.

Session & Token Management

Secure HTTP-only cookies where appropriate or bearer tokens for SPA/mobile. Revoke tokens on logout, password changes and administrative account actions.

Password Policy

Minimum 8 characters with uppercase, lowercase, number and symbol. Store passwords using Argon2id (preferred) or Bcrypt. Prevent reuse of recent passwords where feasible.

Route Protection

Public routes remain unauthenticated. Customer, Admin and Support routes are protected using authentication middleware and role/permission middleware.

Security Controls

Rate limiting, brute-force protection, account lockout, device/session tracking, CSRF protection where applicable and HTTPS-only communication.

Audit Logging

Record registration, login, logout, failed logins, password changes, role changes and privileged administrative actions with timestamps and correlation IDs.

Future Enhancements

Support MFA, passkeys/WebAuthn, social login, adaptive authentication and risk-based access controls without breaking existing APIs.

Acceptance Criteria

Only authorized users access protected resources, permissions are consistently enforced, authentication events are audited and all sensitive operations require valid authentication.